Name: James Jordon	**Date:** 3 February 2026

Module 5

CompTIA Security+ Exam Objectives

Domain	**Lab**
Threats, Vulnerabilities, and Mitigation	5.1, 5.2, 5.4, 5.5
Security Operations	5.1, 5.2, 5.3, 5.4, 5.5

Website links change frequently. If a link in the following activities no longer works, use a search engine such as Google or Bing to search for the information.

Lab 5.3 Examining Secure Cookies and HTTP Response Headers

Estimated Time: 30 minutes

Objectives

Examining HTTP response headers and secure cookies are two practices that can improve security for web servers. Although not all response headers are used to improve security, several are, including HTTP Strict Transport Security (HSTS), Content Security Policy (CSP), Cross-Site Scripting Protection (X-XSS), and X-Frame-Options. While you can examine headers in a browser, understanding how to examine them using command-line tools, such as Curl, is useful for security professionals.

After completing this lab, you will be able to do the following:

- Examine HTTP response headers in Windows.
- Identify whether a website is using secure cookies.

Certification Objectives

Objectives for the CompTIA Security+ exam:

- 4.1 Given a scenario, apply common security techniques to computing resources.

Materials Required

This lab requires the following:

- A computer running the Windows operating system

Activity

In this lab, you examine secure cookies and HTTP response headers for a few websites using Windows command-line tools.

1. Click the **Start** button on the Windows taskbar, type **cmd**, and then press **Enter** to display the Command Prompt option. If a dialog box opens asking if you want to allow the application to make changes to your system, click **Yes**.

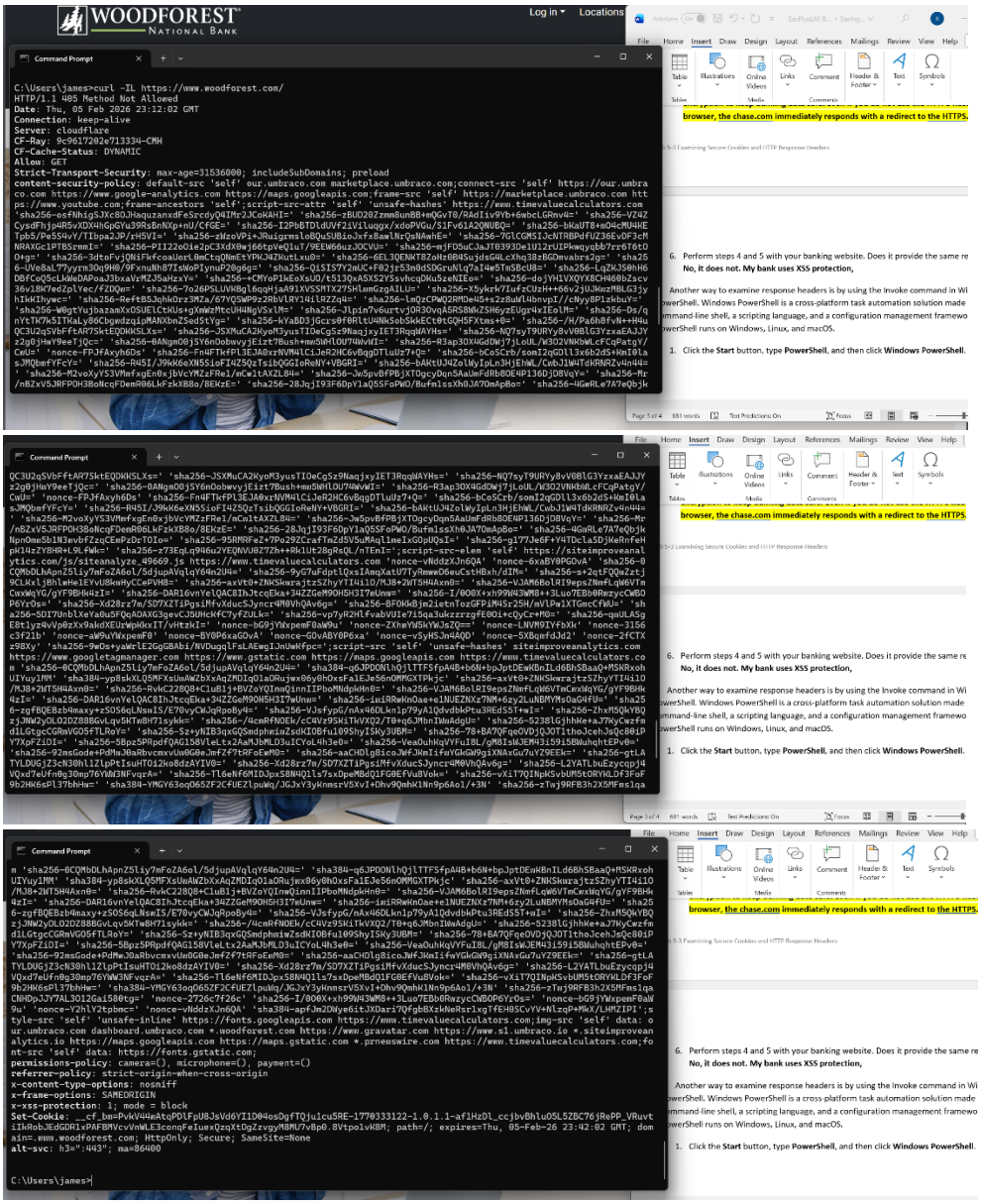
2. In the right pane of the search results, click **Run as administrator**.

3. Type **curl -IL www.google.com** and press **Enter** to view the HTTP response headers for Google. Examine the Set-Cookie lines. Do all the Set-Cookies have the word *secure* in them? **No, only the first set cookie was secure according to the command prompt.**

4. Type **curl -IL www.chase.com** and press **Enter** to view the HTTP response headers for the Chase banking website. What are the differences between the Chase and Google websites? What do you notice about the server response in the initial header section? Why do you think Chase is different from Google? **Chase uses XSS protection and cache control to avoid SQL injections, unlike Google which did not use any XSS protections. You could not view the cookies by Chase.com. Due to Chase being a financial institution, they must follow strict guidelines to protect consumer personal information, therefore, the website is more secure with redirects to safe pages. Google, on the contrary, has visual cookies and is based on simplicity and performance.**

5. Type **curl -IL https://www.chase.com** and press **Enter** to view the HTTPS-specific response headers for the same banking website. What do you notice about the server response and headers with HTTPS specified? What can you tell is happening when you type www.chase.com without specifying HTTPS in the browser? **I noticed that the server responded immediately with an HTTPS handling due to the necessity for extra encryption to keep banking data safe. Even if you do not use the HTTPS heading in the browser, the chase.com immediately responds with a redirect to the HTTPS.**

6. Perform steps 4 and 5 with your banking website. Does it provide the same response? **No, it does not. My bank utilizes Cloudfaver servers. You can see the content security policy in some plain-text. It does utilize HTTPS redirection and XSS protection. You can, however, see the secure set-cookie it uses. (Screenshots 1, 2, and 3 fro curl -IL https://www.woodforest.com/)**



Another way to examine response headers is by using the Invoke command in Windows PowerShell. Windows PowerShell is a cross-platform task automation solution made up of a

command-line shell, a scripting language, and a configuration management framework. PowerShell runs on Windows, Linux, and macOS.

1. Click the **Start** button, type **PowerShell**, and then click **Windows PowerShell**.

2. In the right pane of the search results, click **Run as administrator**.

3. Type **Invoke-WebRequest -Uri www.google.com | Select-Object -ExpandProperty Headers** and press **Enter** to examine the Google headers from PowerShell.

4. Type **Invoke-WebRequest -Uri www.chase.com | Select-Object -ExpandProperty Headers** and press **Enter** to examine the Chase headers from PowerShell. Is any of the information provided by Curl different from the information provided by Invoke-WebRequest in PowerShell? **The "curl -IL" will show you the redirects while the Powershell will only show you after its been redirected automatically. The Powershell also may use HTTP2 or HTTP3 based on the websites security.**

```
PS C:\WINDOWS\system32>  Invoke-WebRequest -Uri www.chase.com | Select-Object -ExpandProperty Headers

Security Warning: Script Execution Risk
Invoke-WebRequest parses the content of the web page. Script code in the web page might be run when the page is
parsed.
      RECOMMENDED ACTION:
      Use the -UseBasicParsing switch to avoid script code execution.

      Do you want to continue?

[Y] Yes  [A] Yes to All  [N] No  [L] No to All  [S] Suspend  [?] Help (default is "N"): Y

Key                           Value
---                           -----
x-nextjs-cache                STALE
x-envoy-upstream-service-time 0
Accept-CH                     Sec-CH-UA-Full-Version-List, Sec-CH-UA-Platform-Version, Sec-CH-UA-Arch, Sec-CH-UA-Mod...
Permissions-Policy            ch-ua-full-version-list=("https://*.chase.com"),ch-ua-platform-version=("https://*.cha...
x-frame-options               SAMEORIGIN
Content-Security-Policy       frame-ancestors 'none'
x-content-security-policy     frame-ancestors 'none'
x-xss-protection              1; mode=block
X-Akamai-Transformed          9 - 0 pmb=mRUM,2
Transfer-Encoding             chunked
Connection                    keep-alive,Transfer-Encoding
Server-Timing                 cdn-cache; desc=HIT,edge; dur=1,ak_p; desc="1770335526334_388842189_79173907_20_6443_3...
Strict-Transport-Security     max-age=31536000
x-amzn-trace-id               0.cd422d17.1770335526.4b81913
```

```
PS C:\WINDOWS\system32>  Invoke-WebRequest -Uri www.google.com | Select-Object -ExpandProperty Headers

Security Warning: Script Execution Risk
Invoke-WebRequest parses the content of the web page. Script code in the web page might be run when the page is
parsed.
      RECOMMENDED ACTION:
      Use the -UseBasicParsing switch to avoid script code execution.

      Do you want to continue?

[Y] Yes  [A] Yes to All  [N] No  [L] No to All  [S] Suspend  [?] Help (default is "N"): Y

Key                                Value
---                                -----
Content-Security-Policy-Report-Only object-src 'none';base-uri 'self';script-src 'nonce-dmWgyD-vDsb0K_t6zYaL4w' 'str...
Reporting-Endpoints                default="//www.google.com/httpservice/retry/jserror?ei=5SyFaYStNcimqtsP6tGAmAo&c...
X-XSS-Protection                   0
X-Frame-Options                    SAMEORIGIN
Cache-Control                      private, max-age=0
Content-Type                       text/html; charset=UTF-8
Date                               Thu, 05 Feb 2026 23:51:01 GMT
Expires                            -1
P3P                                CP="This is not a P3P policy! See g.co/p3phelp for more info."
Set-Cookie                         __Secure-STRP=AD6DogshScAFHv_DRvUT15T7mpq0kkshgmTHhvO1b0yGJ0Lf-1hq2T04HH_tXMbqor...
Server                             gws
Accept-Ranges                      none
Vary                               Accept-Encoding
Transfer-Encoding                  chunked
```

```
Windows PowerShell
      RECOMMENDED ACTION:
      Use the -UseBasicParsing switch to avoid script code execution.

      Do you want to continue?

[Y] Yes  [A] Yes to All  [N] No  [L] No to All  [S] Suspend  [?] Help (default is "N"): Y

Key                           Value
---                           -----
x-nextjs-cache                STALE
x-envoy-upstream-service-time 0
Accept-CH                     Sec-CH-UA-Full-Version-List, Sec-CH-UA-Platform-Version, Sec-CH-UA-Arch, Sec-CH-UA-Mod...
Permissions-Policy            ch-ua-full-version-list=("https://*.chase.com"),ch-ua-platform-version=("https://*.cha...
x-frame-options               SAMEORIGIN
Content-Security-Policy       frame-ancestors 'none'
x-content-security-policy     frame-ancestors 'none'
x-xss-protection              1; mode=block
X-Akamai-Transformed          9 - 0 pmb=mRUM,2
Transfer-Encoding             chunked
Connection                    keep-alive,Transfer-Encoding
Server-Timing                 cdn-cache; desc=HIT,edge; dur=1,ak_p; desc="1770335526334_388842189_79173907_20_6443_3...
Strict-Transport-Security     max-age=31536000
x-amzn-trace-id               0.cd422d17.1770335526.4b81913
Cache-Control                 public, max-age=3600
Content-Type                  text/html; charset=utf-8
Date                          Thu, 05 Feb 2026 23:52:06 GMT
ETag                          "5g0s9jmlfg8j92"

PS C:\WINDOWS\system32> |
```